

Sovereign AI Is a Hardware Problem

What deploying a sovereign LLM stack across three continents taught me about trust, hardware, and what 'sovereignty' actually means below the API layer.

Lei Zhou

Systems Architect · Platform Security Practitioner
github.com/zlhk100 · linkedin.com/in/leizhou · medium.com/@zlhk100

TAICO Toronto · July 22, 2026

A different vantage point.

A platform security and systems architect who built a sovereign LLM stack — and noticed things you only see when you look below the API.



Platform Security

25+ years across firmware and OS,
platform security and software stacks
across embedded systems and HPC —
hardware-rooted trust: Secure Enclave,
secure boot and Confidential Computing,
Remote attestation, Autonomous
Security



Mixed-Criticality Systems

WCET deterministic timing analysis and
workload optimization, virtualization, and
heterogeneous computing platform
automotive SDV and Physical AI



AI Infrastructure

Designed and deployed a three-tier
sovereign LLM stack across EU, NA, and
Asia-Pacific jurisdictions

“We will reinforce Canadian sovereignty so Canadians can make their own choices on how AI is built, governed, and used.”

Prime Minister Mark Carney · June 4, 2026 · AI for All — Canada’s National AI Strategy

\$2B+

Federal AI Investment

\$890M

Sovereign Compute Infrastructure

250K

New AI Jobs Target by 2031

The government has named the problem. Tonight: what the engineering layer reveals.

Where most sovereign AI conversations stop.



You've picked your cloud provider



You've set your data residency policy



You've chosen an open-weight model



The sovereignty box is checked

I thought we'd answered it.

Until I looked below the API gateway.

What sovereignty actually means below the API layer

Gaps appear when you look below the API — specific to MaaS deployment model most teams start with

Data residency governs where data is stored — not where it is processed

- 01** Policy tells you which region your data lives in. It says nothing about what happens to it during inference — on hardware you don't control, processed by a stack you can't inspect.

Prompt and inference state run on shared GPU infra — w/o verifiable tenant isolation

- 02** During prefill, your prompt tokens are processed on GPU compute shared across tenants. During decode, the KV cache — intermediate attention state derived from your prompt — persists in shared GPU memory for the full duration of the request. Standard MaaS provides no documented per-tenant GPU memory isolation. The isolation question cannot be audited from the tenant side.

The hardware platform has a trust chain that begins before your deployment boundary

- 03** Data residency policies govern where hardware is operated. They don't address who manufactured it, what firmware it runs, or who has privileged access to service it. The sovereignty boundary most organisations draw starts at the software layer. The hardware sits outside it.

“Can you attest to what’s actually running on the hardware processing your most sensitive inference workloads?”

What MaaS gives you

- Network isolation
- Provider policy
- Hypervisor boundary

What MaaS does NOT give you

- Hardware state verification
- Cryptographic proof of isolation
- Attestation of co-tenants
- Proof of model integrity (which model binary is actually executing?)

A three-tier sovereign LLM stack

Deployed across EU, NA, and Asia-Pacific jurisdictions

Centralised Gateway

Unified API endpoint · Enterprise SSO/OIDC · Per-project budget enforcement · Full spend audit trail ·
Provider-agnostic routing

Tier 1

Hosted Frontier APIs

General productivity and
development workflows
Non-sensitive workloads
Managed by provider

Trust: Provider policy

Tier 2

Regional Sovereignty Nodes

NDA-constrained work
Self-hosted per jurisdiction
Data never leaves region

Trust: Architecture + policy

Tier 3

Edge / Local Inference

Zero-exfiltration developer tooling
On-device model
Air-gapped if needed

Trust: Physical control

Who are we actually defending against?

Threat actor taxonomy for sovereign AI infrastructure



External Attacker

Credential stuffing, API key theft, prompt injection



Compromised Insider

Phishing or malware on engineer machine — sensitive IP exfiltration



Malicious Insider

Legitimate access abused for competitive intelligence or IP theft



Cloud Provider (CSP)

Regulatory compulsion — CLOUD Act, GDPR conflict, gov subpoena



Supply Chain

Compromised container image, dependency CVE in model runtime



Three trust boundaries — not one

Where your security controls actually live

TB1

Internet Boundary

Where engineers connect from the outside world

TLS 1.3 · Authentication · API key validation · Rate limiting

TB2

Internal Service Boundary

Between components inside the sovereignty perimeter

In-cluster communication · Service identity · Encrypted secrets

TB3

Sovereignty Boundary

The jurisdictional perimeter — data stays inside

Private cluster · No internet egress · Encryption key management · Data residency enforcement

Evaluating cloud providers for sovereign AI

Going beyond price and latency — four dimensions that actually matter

01

Data Residency Verification

Can the provider prove data doesn't leave the jurisdiction — contractually and technically?

03

Compliance Certification Depth

What standards are certified? By whom? How current? What's the audit trail?

02

Hardware Trust Capability

Does the provider support hardware attestation, confidential computing instances, or dedicated hardware options?

04

Jurisdictional Independence

Is the infrastructure truly independent of foreign legal jurisdiction — even under regulatory compulsion?

Benchmark scores lie. Hardware tells the truth.

Why hardware-aware evaluation changes which model you choose

The same model produces different results on different hardware. Benchmark leaderboards assume unlimited compute. Production assumes your sovereignty constraint.

Coding Capability

Metric: SWE-bench score

Frontier models lead—but open-weight closes fast

Inference Throughput

Metric: Tokens/sec @ concurrent load

Hardware determines this—not the model card

Security Analysis

Metric: Vulnerability detection rate

Specialised models outperform general-purpose

Data Sovereignty

Metric: Deployment architecture

This is the constraint that overrides all others

Protection matrix: 4 architectures, 7 dimensions

The full spectrum — from common practice to hardware-verified sovereignty

Protection Dimension	Managed MaaS	Cloud VM (Open-weight)	Dedicated Hardware	Confidential Computing
Data at rest	✓ Encrypted	✓ Encrypted	✓ Encrypted	✓ Hardware-backed
Data in transit	✓ TLS	✓ TLS	✓ TLS	✓ TLS + PCIe IDE
Data in use (DRAM) *	✗ Plaintext	✗ Plaintext	○ Reduced risk	✓ Encrypted (CPU+GPU)
Hypervisor access	✗ Full access	○ Provider mgd	N/A (bare metal)	✓ Blocked (HW enforced)
Physical isolation	✗ Shared	✗ Shared	✓ Dedicated	✓ Dedicated
Remote attestation	✗ Not available	✗ Not available	✗ Not available	✓ SPDM / DICE
NDA defensibility	✗ Low	○ Medium	○ Medium-high	✓ Highest

* In LLM inference, "data in use" includes the KV cache — prompt tokens and intermediate attention values held in plaintext GPU DRAM during active inference. This is the attack surface that memory encryption targets.

Two communities. One conclusion.

Enforcement cannot live in the same failure domain as what it enforces.

ISO 26262 · Safety Architects

Freedom from Common-Cause Failures (CCF)

A safety monitor must be diverse and independent of the system it monitors. Formal requirement in safety-critical hardware design since the 1990s.

Path: diverse, independent hardware channels

AI Security Researchers

Probabilistic supervision of probabilistic systems

Black-box AI supervision of black-box AI cannot provide a deterministic lower bound for security. Systems with highly correlated failure modes compound, not cancel.

Path: hardware-enforced isolation boundary

What hardware-verified sovereignty looks like

Confidential Computing — where the hypervisor and cloud platform are not trusted



Confidential VM

A hardware-isolated virtual machine. The hypervisor can schedule it but cannot read its memory or inspect its workload. Data in use is protected by CPU hardware — not by provider policy.

Why it matters: Closes the gap MaaS leaves open. The cloud provider's platform software is explicitly outside the trust boundary.



Measured Boot

Every component loaded at boot — firmware, OS, runtime — is cryptographically measured and recorded in tamper-evident hardware.

Why it matters: Proves the software stack inside the Confidential VM is exactly what was specified. Nothing substituted silently.



Remote Attestation (SPDM / DICE)

What: The hardware generates a signed proof of its own state — VM isolation active, boot chain intact — that the tenant verifies directly. No trust in the platform required.

Why it matters: Turns sovereignty from a provider promise into a cryptographic proof the tenant holds and can present to auditors.

*Production implementations: AMD SEV-SNP · Intel TDX · ARM CCA — and the inference story goes deeper.
That's the next talk.*

WHY NOW

Engineering problem today. Compliance problem tomorrow.

The regulatory timeline that makes hardware trust mandatory

2026

Canada AI for All

\$2B sovereign AI investment. Build-partner-buy doctrine. Hardware sovereignty explicit.

Active

EU AI Act

High-risk AI systems require transparency, robustness, and data governance controls.

Dec 2027

EU Cyber Resilience Act

Products with digital elements must meet cybersecurity requirements across their lifecycle.

2027+

Data Sovereignty Laws

GDPR enforcement tightening. Canadian PIPEDA reform. APAC data localisation expanding.

The engineering patterns we've discussed — trust boundary design, hardware-aware CSP evaluation, attestation — appear to be moving in the same direction these regulations are pointing.

Three questions worth sitting with

From my experience building this — offered as prompts, not prescriptions

01

Have you classified workloads by the trust guarantee they actually need?

Not just by data sensitivity — by the trust model the workload actually requires. Policy promise, architectural enforcement, or cryptographic proof? The tier follows from the answer.

02

Does your CSP evaluation include hardware trust capability?

Beyond region availability and compliance certifications — does the provider support hardware attestation or confidential computing instances? Have you asked them directly?

03

Is your LLM gateway designed as a trust boundary — or a cost control with security features added?

Authentication, budget enforcement, audit trail — these live at the gateway. Which of those is the primary design intent in yours?

Sovereignty isn't where your data lives.

It's what your hardware can prove.

Lei Zhou · github.com/zlhk100 · linkedin.com/in/leizhou · medium.com/@zlhk100

Confidential Computing series: medium.com/@zlhk100

Next: “Closing the Gap” — Confidential Computing & Remote
Attestation in depth